

GRC Policy Template Toolkit

Alberto Al Leiva

1 August 2026

Table of Contents

GRC Policy Template Toolkit

This toolkit contains educational starter templates. It does not constitute legal, regulatory, privacy, labor, accounting, certification, or formal audit advice. Each template must be adapted, reviewed, approved, implemented, and evidenced for the adopting organization.

Policy Governance and Document Hierarchy

Purpose

Policies establish management direction, mandatory principles, accountability, and boundaries. They should be concise enough to govern decisions and stable enough to remain useful as technology and procedures change.

A policy template is not an adopted policy. Adoption requires organization-specific analysis, accountable ownership, appropriate review, formal approval, communication, implementation, and retained evidence.

Document hierarchy

A practical hierarchy distinguishes:

- **Policy** — mandatory direction and principles approved by authorized management.
- **Standard** — mandatory, measurable requirements supporting policy.
- **Procedure** — ordered steps for performing an activity.
- **Guideline** — recommended practice where discretion is permitted.
- **Plan** — roles, actions, resources, and timing for a defined scenario.
- **Record** — evidence that an activity, decision, or control occurred.

Do not place detailed configuration values, rapidly changing contacts, or step-by-step instructions in a high-level policy unless governance requires them there.

Minimum policy metadata

Every controlled policy should identify:

- title and unique identifier;
- version and status;
- policy owner;
- approving authority;
- approval and effective dates;
- next review date;
- classification;
- applicable entities, workforce groups, locations, systems, and data;
- related standards, procedures, plans, and records;
- exception authority;
- revision history.

Governance roles

Governing body or executive leadership

Approves risk appetite, major policy direction, and material exceptions according to delegated authority.

Policy owner

Maintains content, coordinates review, confirms implementation, monitors exceptions, and initiates revision.

Control and process owners

Implement requirements, operate controls, retain evidence, and report noncompliance or barriers.

Legal, privacy, human resources, compliance, records, and labor specialists

Review areas within their competence. Their review is required when a policy affects legal rights, monitoring, privacy, employment, investigations, retention, cross-border processing, collective agreements, or regulated activity.

Internal audit or independent assurance

May assess governance and implementation but should not silently assume management ownership of the policy.

Policy design principles

A useful policy is:

- aligned to objectives and risk;
- clear about mandatory versus recommended language;
- measurable where possible;
- realistic for the organization's capabilities;

- consistent with other controlled documents;
- technology-neutral where appropriate;
- explicit about accountability and exceptions;
- supported by procedures, systems, training, and records;
- reviewed when obligations or risk change.

Mandatory language

Use **must** or **shall** for mandatory requirements and **should** for recommendations. Avoid vague expressions such as “as needed,” “regularly,” or “appropriate” unless criteria or delegated judgment are defined.

Scope and applicability

Define who and what the policy covers. Consider employees, contractors, temporary workers, interns, volunteers, service providers, subsidiaries, joint ventures, cloud services, operational technology, mobile devices, remote work, and information in all formats.

Relationship to law and contracts

Policies must not presume that one jurisdiction’s rule applies universally. Record the applicable legal entities and jurisdictions, and require local addenda where employment, privacy, surveillance, breach notification, retention, accessibility, or sector rules differ.

Policy conflicts

Establish an escalation route for conflicts among law, regulation, contract, policy, standard, and operational constraints. Do not direct personnel to violate a higher-priority obligation. Record the decision and required compensating measures.

Template Adaptation, Approval, and Publication

Purpose

A template must be converted into an organization-specific controlled document before it is relied upon. Placeholders, optional clauses, example frequencies, and generic roles must be resolved through documented review.

Adaptation workflow

1. Identify the legal entity, jurisdictions, business units, systems, data, workforce, and third parties in scope.
2. Map applicable laws, regulations, contracts, standards, customer commitments, and internal risk decisions.
3. Assign an accountable policy owner and drafting team.
4. Resolve every placeholder and optional clause.
5. Align terminology with the organization’s document hierarchy and operating model.

6. Confirm that required procedures, technology, staffing, training, and records exist or are funded.
7. Conduct legal, privacy, human-resources, records, compliance, security, and accessibility review as applicable.
8. Resolve conflicts and record material decisions.
9. Obtain approval from the delegated authority.
10. Publish through the controlled repository, communicate, train, implement, and retain evidence.

Placeholder controls

Templates use bracketed fields such as [ORGANIZATION], [POLICY OWNER], [TIME PERIOD], and [APPROVING AUTHORITY]. A release check must fail when unresolved placeholders remain, except where an approved form intentionally prompts the user for data.

Optional clauses

Optional clauses should be selected based on risk and obligations, not copied automatically. Remove instructions and drafting notes from the approved version. Record why material clauses were included, modified, or omitted.

Review evidence

Retain evidence of:

- reviewers and dates;
- comments and resolutions;
- legal or regulatory assumptions;
- risk decisions;
- approval authority;
- final controlled version;
- communication and training;
- implementation dependencies;
- exceptions and local addenda.

Approval

Approval confirms management direction and accountability. It does not certify legal compliance or control effectiveness. The approval record should identify the version, effective date, implementation deadline, and any conditions.

Publication

Publish only the approved controlled copy. Prevent obsolete drafts from appearing authoritative. Approved policies should be searchable, accessible to the intended audience, protected from unauthorized change, and available during outages when operationally necessary.

Communication and acknowledgement

Choose communication methods proportionate to impact. High-impact policies may require role-based training, translated or accessible formats, manager briefings, and acknowledgements. An acknowledgement proves receipt or attestation, not understanding or compliance.

Local addenda

Use local addenda when laws, labor rules, monitoring restrictions, breach duties, records requirements, or operational conditions vary. Addenda should identify precedence and must not weaken enterprise requirements without approved authority.

Emergency issuance

An emergency policy may use accelerated review when delay creates material risk. Record the basis, temporary approval, effective period, communication, and deadline for full review. Emergency status must not become indefinite.

Implementation, Evidence, Training, and Monitoring

Purpose

A policy is effective only when supporting controls, resources, procedures, training, and monitoring are operating. Publication alone does not establish implementation.

Implementation plan

For each material requirement, identify:

- accountable owner;
- supporting standard or procedure;
- technology or process dependency;
- required budget and staffing;
- implementation deadline;
- affected population;
- training or communication;
- evidence source;
- monitoring method;
- escalation route.

Evidence of implementation

Evidence may include approved standards and procedures, configuration exports, access records, training completion, logs, review reports, incident records, test results, vendor records, exception approvals, management reports, and corrective actions.

Evidence should be authentic, complete, current, traceable, appropriately protected, and retained according to applicable requirements.

Training

Training should be role-based and timed to the policy's effective date. Specialized roles may require exercises, technical instruction, or competency validation. Maintain accessible alternatives and reasonable accommodations where required.

Monitoring

Monitoring should determine whether requirements are implemented and operating, not merely whether the policy exists. Useful measures include:

- implementation completion;
- overdue dependencies;
- exception volume and age;
- repeated violations;
- training completion and assessment results;
- control failures;
- incident or loss trends;
- corrective-action status;
- policy questions and ambiguity indicators.

Noncompliance

Define fair, consistent escalation. Noncompliance may result from misconduct, unclear requirements, unavailable resources, system defects, conflicting obligations, or unrealistic deadlines. Investigate the facts and apply human-resources, legal, contractual, and disciplinary processes as applicable.

Automation and AI

Automated tools may assist with distribution, acknowledgement, mapping, monitoring, and draft analysis. They must not invent approvals, legal conclusions, implementation evidence, exceptions, or review results. Human accountability remains with the designated owner and approver.

Accessibility and language

Provide policies in formats and languages needed by the intended audience. Automated translation is a publication candidate, not proof of native-language accuracy. Accessibility testing in native applications should be performed where required.

Continuous improvement

Use incidents, audit findings, user feedback, legal changes, control failures, technology changes, and business changes to improve policy design. Preserve revision history and avoid silent changes to mandatory requirements.

Exceptions, Review, Records, and Lifecycle

Exceptions

An exception is a documented, approved deviation from a policy requirement. It should not be used to conceal noncompliance or avoid funding a known control indefinitely.

An exception record should identify:

- policy and requirement;
- requester and business justification;
- affected systems, people, data, and period;
- risk assessment;
- legal, privacy, contractual, and operational review;
- compensating controls;
- accountable owner;
- approval authority;
- start and expiration dates;
- monitoring and review frequency;
- remediation or exit plan;
- revocation conditions.

Exception authority

Approval authority should reflect risk. High-risk exceptions may require executive, risk-committee, legal, privacy, customer, regulator, or governing-body involvement. The policy owner should not approve an exception outside delegated authority.

Review triggers

Review policies on a defined cycle and when triggered by:

- material legal or regulatory change;
- new or changed contractual commitments;
- incidents or control failures;
- significant audit findings;
- mergers, acquisitions, divestitures, or restructuring;
- new technology, AI, cloud, or operational technology;
- changes in data processing or monitoring;

- workforce or labor changes;
- significant supplier changes;
- repeated exceptions or ambiguity.

Periodic review

A review should confirm continuing need, scope, ownership, consistency, implementation, evidence, exceptions, and alignment with current risk. “Reviewed with no changes” still requires a dated record and accountable approval according to governance.

Revision control

Maintain a revision history showing version, date, summary, author, reviewers, and approver. Material changes should be communicated and may require retraining or renewed acknowledgement.

Withdrawal and archival

When a policy is replaced or withdrawn:

- identify the successor document;
- state the effective withdrawal date;
- remove obsolete public copies;
- preserve required records;
- update mappings, procedures, training, and contracts;
- communicate the change;
- retain historical versions according to records requirements.

Records

Policy records may include drafts, comments, approvals, legal review, acknowledgements, training, implementation evidence, exceptions, monitoring, incidents, investigations, and revision history. Classify and protect these records; some may contain privileged, personal, security-sensitive, or confidential information.

Metrics and reporting

Report policy status, overdue reviews, unresolved placeholders, implementation gaps, exceptions, recurring noncompliance, training, and corrective actions. Avoid metrics that reward rapid approval while ignoring implementation quality.

Toolkit use sequence

1. Read the implementation manual.
2. Select only applicable templates.
3. resolve all placeholders and drafting notes.
4. perform jurisdictional and specialist review.
5. approve through delegated governance.

6. publish the controlled copy.
7. implement procedures, controls, training, and records.
8. monitor performance and exceptions.
9. review, revise, or withdraw through controlled lifecycle management.

Information Security Policy Template

Drafting notice: Resolve every bracketed field and obtain legal, privacy, human-resources, compliance, records, security, and accessibility review as applicable before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approving authority: [APPROVING AUTHORITY]
- Version: [VERSION]
- Effective date: [DATE]
- Next review: [DATE]
- Classification: [CLASSIFICATION]

1. Purpose

[ORGANIZATION] establishes this policy to protect information, technology, services, people, and business objectives through risk-based governance and security controls.

2. Scope

This policy applies to [LEGAL ENTITIES, WORKFORCE, CONTRACTORS, LOCATIONS, SYSTEMS, DATA, CLOUD SERVICES, AND THIRD PARTIES].

3. Principles

[ORGANIZATION] must:

- manage information-security risk within approved risk appetite;
- assign accountable owners for information, systems, services, and controls;
- apply security throughout acquisition, design, development, operation, change, and disposal;
- protect confidentiality, integrity, availability, authenticity, and resilience according to risk;
- comply with applicable legal, regulatory, contractual, privacy, records, and customer requirements;
- maintain incident, continuity, recovery, supplier, vulnerability, identity, logging, and monitoring capabilities;
- provide role-based awareness and training;

- measure control performance and address deficiencies;
- document and approve exceptions.

4. Governance

[GOVERNING BODY OR EXECUTIVE] approves security direction and risk appetite. [CISO OR SECURITY LEADER] coordinates the security program. Business, data, system, process, and control owners remain accountable for risks and controls within their authority.

5. Risk management

Security risks must be identified, assessed, treated, monitored, and reported using [RISK METHODOLOGY]. Risk acceptance must be approved by [AUTHORITY] and reviewed by [FREQUENCY].

6. Asset and information management

Information and technology assets must be inventoried, assigned owners, classified, handled, retained, and disposed of according to approved requirements.

7. Identity and access

Access must be authorized, least-privileged, periodically reviewed, promptly changed or revoked, and protected with authentication controls proportionate to risk.

8. Secure technology lifecycle

Security requirements must be included in architecture, acquisition, development, configuration, testing, deployment, change, maintenance, and decommissioning.

9. Operations and resilience

[ORGANIZATION] must maintain vulnerability management, malware protection, backup, recovery, logging, monitoring, capacity, configuration, incident response, continuity, and disaster-recovery controls proportionate to risk.

10. Third parties

Security and privacy risks arising from suppliers and other third parties must be assessed, contractually addressed, monitored, and managed through termination or transition.

11. Reporting

Suspected security incidents, control failures, policy violations, and material risks must be reported through [REPORTING CHANNEL] without retaliation where protected by law.

12. Exceptions

Exceptions require documented justification, risk assessment, compensating controls, owner, expiration date, monitoring, and approval by [EXCEPTION AUTHORITY].

13. Enforcement

Violations may result in corrective, contractual, or disciplinary action consistent with applicable law, contracts, workforce rules, due process, and approved procedures.

14. Related documents

[LIST STANDARDS, PROCEDURES, PLANS, AND REGISTERS]

15. Review and approval

This policy must be reviewed at least [FREQUENCY] and after material changes. Approval records and revision history must be retained.

Access Control Policy Template

Resolve all placeholders and review employment, privacy, monitoring, privileged-access, customer, and regulatory requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements for granting, using, reviewing, changing, and revoking access to [ORGANIZATION] information, systems, services, facilities, and administrative functions.

2. Scope

Applies to [USERS, WORKFORCE, CONTRACTORS, SERVICE ACCOUNTS, APPLICATIONS, DEVICES, THIRD PARTIES, CLOUD AND ON-PREMISES SYSTEMS].

3. Requirements

3.1 Identity

Each user must use an approved unique identity unless a documented technical exception permits a controlled shared or functional account. Identity records must be traceable to an accountable owner.

3.2 Authorization

Access must be approved by [DATA/SYSTEM/PROCESS OWNER], based on business need, least privilege, segregation of duties, and approved role definitions.

3.3 Authentication

Authentication strength must reflect risk. Multi-factor authentication is required for [DEFINED SYSTEMS, REMOTE ACCESS, PRIVILEGED ACCESS, AND OTHER USE CASES], subject to approved alternatives and accessibility accommodations.

3.4 Privileged access

Privileged access must be separately authorized, limited, monitored, reviewed, and used only for approved administrative activity. Emergency access must be time-bound and reviewed after use.

3.5 Joiner, mover, and leaver controls

Access must be provisioned, modified, suspended, and revoked within [TIMEFRAMES] based on authoritative workforce or contractual events. Exceptions and failed notifications must be reconciled and escalated.

3.6 Access review

Owners must review access at least [FREQUENCY] and after material role, system, risk, or organizational changes. Reviews must cover privileged, dormant, service, third-party, and conflicting access.

3.7 Service and machine identities

Service accounts, API credentials, certificates, secrets, and machine identities must have owners, documented purpose, least privilege, secure storage, rotation, monitoring, and retirement controls.

3.8 Remote and third-party access

Remote and third-party access must use approved methods, defined time periods, security controls, logging, and termination procedures.

3.9 Logging and monitoring

Authentication, authorization, privileged activity, access changes, and significant failures must be logged and monitored according to the Logging and Monitoring Policy and applicable privacy rules.

4. Exceptions

Exceptions require documented risk, compensating controls, owner, expiration, and approval by [AUTHORITY].

5. Records

Retain requests, approvals, provisioning records, reviews, exceptions, logs, and revocation evidence according to [RETENTION REQUIREMENT].

6. Enforcement and review

Violations are handled under approved procedures and applicable law. This policy is reviewed at least [FREQUENCY] and after material identity, technology, legal, or organizational change.

Acceptable Use Policy Template

Review workforce, monitoring, privacy, labor, accessibility, whistleblower, and local-law requirements before adoption.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy defines acceptable and prohibited use of [ORGANIZATION] information, technology, communications, accounts, networks, devices, facilities, and services.

2. Scope

Applies to [WORKFORCE, CONTRACTORS, TEMPORARY PERSONNEL, VOLUNTEERS, THIRD PARTIES, DEVICES, NETWORKS, CLOUD SERVICES, AND PERSONALLY OWNED DEVICES WHEN AUTHORIZED].

3. General responsibilities

Users must:

- use resources primarily for authorized purposes;
- protect credentials, devices, information, and physical access;
- follow classification, handling, retention, privacy, and records requirements;
- promptly report loss, suspected compromise, prohibited content, incidents, or control failure;
- comply with licenses, intellectual-property rights, contracts, and applicable law;
- avoid actions that create unreasonable security, operational, legal, or reputational risk.

4. Prohibited activities

Unless expressly authorized for legitimate duties, users must not:

- access, alter, disclose, copy, or destroy information without authorization;
- bypass security, monitoring, access, or licensing controls;
- install unapproved software, services, extensions, or devices;
- introduce malware, conduct unauthorized testing, or interfere with services;
- share credentials or use another person's identity;
- use resources for harassment, discrimination, retaliation, unlawful surveillance, fraud, theft, or prohibited content;
- store organizational information in unapproved personal accounts or services;
- make unauthorized public statements or commitments on behalf of [ORGANIZATION];
- use generative AI or external tools with restricted information contrary to approved requirements.

5. Limited personal use

[ORGANIZATION POLICY ON PERSONAL USE]. Personal use must not interfere with work, consume unreasonable resources, create risk, violate law or policy, or imply organizational endorsement.

6. Monitoring and privacy

Use may be logged, monitored, reviewed, or disclosed only as authorized by law, policy, contracts, notices, and approved procedures. This clause must be adapted to local privacy and labor requirements. It does not eliminate rights that cannot lawfully be waived.

7. Remote work and mobile use

Users must follow approved remote-access, device-security, physical-privacy, travel, and information-handling requirements. Loss or theft must be reported within [TIMEFRAME].

8. AI and automation

Users must follow [AI USE POLICY OR STANDARD], validate outputs, protect confidential and personal information, respect intellectual property, and retain human accountability for decisions.

9. Exceptions

Exceptions require documented business need, risk review, compensating controls, duration, and approval by [AUTHORITY].

10. Enforcement and acknowledgement

Violations may result in corrective, disciplinary, contractual, or legal action consistent with applicable law and due process. Acknowledgement records must be retained according to [RETENTION REQUIREMENT].

Incident Response Policy Template

Drafting notice: Resolve and adapt legal, regulatory, contractual, privacy, insurance, law-enforcement, privilege, and breach-notification requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes governance for preparing for, detecting, reporting, analyzing, containing, eradicating, recovering from, and learning from cybersecurity, privacy, technology, and information incidents.

2. Scope

Applies to [ENTITIES, WORKFORCE, SYSTEMS, DATA, FACILITIES, CLOUD, OPERATIONAL TECHNOLOGY, SUPPLIERS, AND SERVICES].

3. Governance

[INCIDENT RESPONSE LEADER] coordinates response. Legal, privacy, communications, human resources, business continuity, technology, security, records, insurance, and executive stakeholders participate according to incident type and severity.

4. Reporting

Suspected incidents must be reported immediately through [CHANNELS]. Personnel must preserve evidence and must not conduct unauthorized investigation, communication, or remediation that could increase harm.

5. Classification and escalation

Incidents must be classified using [SEVERITY MODEL], considering safety, operations, data, customers, legal duties, financial impact, third parties, and public interest. Escalation timeframes are [TIMEFRAMES].

6. Response requirements

The organization must maintain and exercise capabilities for:

- preparation and contact management;
- detection and intake;
- triage and analysis;
- containment and business-risk decisions;
- eradication and secure recovery;
- evidence preservation and chain of custody;
- legal, privacy, contractual, insurer, customer, regulator, and law-enforcement coordination;
- internal and external communications;
- post-incident review and corrective action.

7. Decision authority

Authority for system isolation, service shutdown, public communication, ransom-related decisions, customer notification, regulator notification, and law-enforcement referral must be assigned in [INCIDENT RESPONSE PLAN].

8. Evidence and records

Incident records must be accurate, time-stamped, access-controlled, and retained according to legal hold, privilege, privacy, contract, insurance, and records requirements.

9. Third parties

Contracts and operating procedures must define supplier reporting, cooperation, evidence, notification, recovery, and post-incident obligations.

10. Exercises and improvement

Plans must be tested at least [FREQUENCY] and after material change. Lessons and corrective actions must be assigned, tracked, validated, and reported.

11. Exceptions

Exceptions require documented risk, duration, compensating controls, and approval by [AUTHORITY].

Business Continuity and Disaster Recovery Policy Template

Adapt safety, emergency-management, regulatory, contractual, insurance, labor, accessibility, and local-resilience requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements to protect people, maintain or restore prioritized products and services, recover technology and information, and coordinate response to disruptive events.

2. Scope

Applies to [ENTITIES, LOCATIONS, BUSINESS SERVICES, TECHNOLOGY, INFORMATION, WORKFORCE, FACILITIES, SUPPLIERS, AND DEPENDENCIES].

3. Governance

[EXECUTIVE SPONSOR] provides oversight. [CONTINUITY OWNER] maintains the program. Business-service owners identify priorities and dependencies. Technology owners maintain recovery capabilities aligned to approved objectives.

4. Business impact analysis

Prioritized activities must have documented impact analysis covering safety, customer, legal, operational, financial, data, supplier, and reputational consequences over time.

5. Recovery objectives

Management must approve recovery time objectives, recovery point objectives, minimum service levels, maximum tolerable disruption, and dependency assumptions for [DEFINED SERVICES].

6. Plans

The organization must maintain accessible, controlled plans for crisis management, business continuity, technology disaster recovery, communications, workforce continuity, facilities, and supplier disruption as applicable.

7. Backup and recovery

Backups must be protected, monitored, tested, retained, and separated according to risk. Recovery procedures must address integrity, authorization, prioritization, dependencies, and secure return to normal operations.

8. Third-party resilience

Critical suppliers and services must be assessed for continuity capability, concentration, geographic, technology, financial, and transition risk. Contracts should define continuity, testing, notification, recovery, and exit obligations.

9. Exercises and validation

Plans and recovery capabilities must be exercised at least [FREQUENCY] and after material changes. Tests must have objectives, scenarios, participants, results, exceptions, and corrective actions. A successful tabletop does not prove technical recovery.

10. Activation and communication

Activation authority, incident command, employee communication, customer and regulator communication, and return-to-normal decisions must be defined in approved plans.

11. Records and improvement

Retain impact analyses, plans, approvals, tests, recovery evidence, incidents, communications, and corrective actions according to [RETENTION REQUIREMENT].

12. Exceptions

Exceptions require documented risk, interim measures, owner, expiration, and approval by [AUTHORITY].

Third-Party and Vendor Risk Policy Template

Adapt procurement, competition, outsourcing, privacy, sector, sanctions, records, labor, financial, and contractual requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements for identifying, assessing, approving, contracting, monitoring, changing, and terminating third-party relationships and associated supply-chain risks.

2. Scope

Applies to [SUPPLIERS, CONTRACTORS, CONSULTANTS, CLOUD PROVIDERS, PROCESSORS, SUBPROCESSORS, OUTSOURCERS, PARTNERS, SOFTWARE, HARDWARE, DATA, AND OTHER THIRD PARTIES].

3. Inventory and ownership

All in-scope relationships must be recorded in [AUTHORITATIVE REGISTER] with a business owner, service description, data and system access, criticality, locations, subprocessors, contract dates, and exit dependencies.

4. Risk classification

Third parties must be tiered before commitment using criteria such as service criticality, information sensitivity, privileged access, operational dependency, concentration, financial exposure, geography, regulatory relevance, recoverability, and substitutability.

5. Due diligence

Due diligence must be proportionate to risk and may cover security, privacy, resilience, legal, compliance, financial, sanctions, insurance, ethics, accessibility, workforce, and fourth-party dependencies. Evidence limitations and unresolved findings must be documented.

6. Approval and risk decisions

The business owner, procurement, legal, privacy, security, compliance, and other required functions must approve according to [AUTHORITY MATRIX]. Residual risks and exceptions require accountable acceptance.

7. Contract requirements

Contracts should address applicable requirements for security, privacy, confidentiality, use restrictions, audit and assurance, incident notification, cooperation, business continuity, subcontractors, location, data return or deletion, records, insurance, liability, termination, and transition.

8. Ongoing monitoring

Monitoring frequency and depth must reflect risk. Trigger reviews include incidents, control failures, material changes, acquisitions, financial deterioration, new subprocessors, location changes, regulatory action, and repeated service failures.

9. Access and data

Third-party access and data processing must be authorized, least-privileged, time-bound where possible, logged, reviewed, and revoked at termination. Data must be returned, transferred, retained, or securely deleted according to approved requirements.

10. Resilience and exit

Critical relationships must have continuity, recovery, transition, and exit plans. Concentration, lock-in, knowledge transfer, data portability, and replacement lead time must be considered.

11. Records

Retain assessments, approvals, contracts, evidence, findings, monitoring, incidents, exceptions, termination, and deletion or return confirmation according to [RETENTION REQUIREMENT].

12. Exceptions

Exceptions require documented justification, risk, compensating controls, owner, duration, monitoring, and approval by [AUTHORITY].

Data Protection and Privacy Policy Template

This template requires qualified jurisdiction-specific privacy and legal review. Do not assume one privacy law, legal basis, retention period, employee-monitoring rule, or cross-border mechanism applies universally.

Document control

- Policy ID: [POLICY ID]
- Owner: [PRIVACY OR POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes principles and governance for lawful, fair, transparent, secure, and accountable processing of personal information by [ORGANIZATION].

2. Scope

Applies to [LEGAL ENTITIES, WORKFORCE, CUSTOMERS, USERS, APPLICANTS, CHILDREN OR VULNERABLE PEOPLE IF APPLICABLE, THIRD PARTIES, SYSTEMS, LOCATIONS, AND PROCESSING ACTIVITIES].

3. Principles

Personal information must be:

- processed under an identified lawful authority or permitted purpose;
- collected for specified purposes and not incompatibly reused;
- limited to what is necessary;
- accurate and corrected when required;

- retained only as authorized;
- protected according to risk;
- processed transparently and with accountable governance;
- handled in a way that supports applicable rights and remedies.

4. Records of processing

In-scope processing activities must be recorded in [PRIVACY INVENTORY OR RECORD], including purpose, categories, individuals, systems, recipients, locations, legal basis, retention, security, transfers, and owner.

5. Privacy by design

Projects, products, procurement, analytics, AI, monitoring, and material changes must include privacy review early enough to influence decisions. High-risk processing requires [IMPACT ASSESSMENT PROCESS].

6. Notices, choices, and consent

Notices and choices must be clear, accessible, accurate, and provided when required. Consent must be used only where valid and managed according to applicable requirements; it must not be presented as the universal basis for processing.

7. Individual rights

Requests for access, correction, deletion, objection, restriction, portability, withdrawal, appeal, or other applicable rights must be authenticated, logged, evaluated, fulfilled, or lawfully denied within [TIMEFRAMES].

8. Sharing and third parties

Personal information may be shared only for authorized purposes with appropriate contracts, due diligence, access controls, transfer mechanisms, and ongoing oversight.

9. International and cross-border processing

Cross-border processing must be assessed and supported by mechanisms valid for the applicable jurisdictions. Locations and onward transfers must be documented.

10. Retention and disposal

Retention must follow approved schedules, legal holds, contractual duties, and documented business needs. Disposal must be secure and verifiable.

11. Security and incidents

Personal information must be protected by risk-based safeguards. Suspected privacy incidents must be reported through [CHANNEL] and managed under the Incident Response Policy, including notification analysis.

12. Workforce and monitoring

Employee, contractor, and workplace processing requires specific legal, labor, notice, proportionality, and access review. This section must be adapted locally.

13. Accountability

[PRIVACY OFFICER OR RESPONSIBLE ROLE] oversees the program. Business and system owners remain accountable for their processing activities, records, controls, and corrective actions.

14. Exceptions and enforcement

Exceptions require legal and privacy review, documented risk, duration, controls, and approval by [AUTHORITY]. Violations are handled under applicable procedures and law.

Change Management Policy Template

Adapt safety, regulated-system, software-development, operational-technology, segregation-of-duties, emergency-change, records, and customer requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements for planning, assessing, authorizing, testing, implementing, documenting, reviewing, and reversing changes to [ORGANIZATION] technology, information, services, facilities, configurations, and controlled processes.

2. Scope

Applies to [APPLICATIONS, INFRASTRUCTURE, CLOUD, NETWORKS, SECURITY CONTROLS, DATA, OPERATIONAL TECHNOLOGY, FACILITIES, VENDORS, AND CONTROLLED BUSINESS PROCESSES].

3. Change categories

Changes must be classified as [STANDARD, NORMAL, EMERGENCY, MAJOR, OR OTHER APPROVED CATEGORIES] using documented criteria. Classification must not be manipulated to avoid review.

4. Change record

Each non-exempt change must record:

- requester, owner, and implementer;
- business purpose and affected services;
- scope, dependencies, and schedule;
- security, privacy, resilience, data, customer, and regulatory impact;
- testing and acceptance criteria;
- implementation and rollback plan;
- approvals;
- communications;
- result, exceptions, and post-implementation review.

5. Risk assessment and approval

Review depth and approval authority must reflect risk, criticality, segregation of duties, and potential impact. Required reviewers may include business, technology, security, privacy, continuity, architecture, data, supplier, legal, and compliance functions.

6. Testing

Changes must be tested in an appropriate environment before production unless an approved emergency process applies. Test data must be authorized and protected. Results and unresolved limitations must be documented.

7. Segregation of duties

Development, approval, and production implementation responsibilities must be separated where feasible and proportionate to risk. Conflicts require monitoring and approval.

8. Emergency changes

Emergency changes may use accelerated approval only to address urgent risk or service need. They must be documented, authorized by [EMERGENCY AUTHORITY], monitored, and retrospectively reviewed within [TIMEFRAME].

9. Standard changes

Pre-authorized standard changes must be low-risk, repeatable, documented, tested, monitored, and periodically reviewed. Failed or changed conditions require reclassification.

10. Post-implementation review

Major, failed, emergency, security-sensitive, or high-risk changes require review of results, incidents, rollback, control impact, documentation, and lessons.

11. Unauthorized changes

Unauthorized or undocumented changes must be investigated, contained where necessary, reported, and addressed through corrective action.

12. Records, metrics, and exceptions

Retain change records according to [RETENTION REQUIREMENT]. Monitor failed changes, emergency changes, unauthorized changes, rollback, incidents, and overdue reviews. Exceptions require documented risk, controls, duration, and approval by [AUTHORITY].

Vulnerability and Patch Management Policy Template

Adapt product-safety, medical, industrial, operational-technology, cloud, supplier, contractual, end-of-life, and regulatory requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements for identifying, assessing, prioritizing, treating, validating, and reporting vulnerabilities and security updates affecting [ORGANIZATION] assets and services.

2. Scope

Applies to [HARDWARE, SOFTWARE, FIRMWARE, CLOUD, APPLICATIONS, NETWORKS, ENDPOINTS, CONTAINERS, OPERATIONAL TECHNOLOGY, MOBILE, THIRD-PARTY SERVICES, AND INTERNET-FACING ASSETS].

3. Asset and ownership prerequisites

In-scope assets must be inventoried with owner, criticality, exposure, technology, support status, and business service. Unknown assets and ownership gaps must be reported and addressed.

4. Vulnerability identification

[ORGANIZATION] must use approved sources and methods such as authenticated scanning, application testing, cloud assessment, supplier notifications, threat intelligence, configuration review, penetration testing, code analysis, and coordinated disclosure.

Testing must be authorized, safely planned, and appropriate to the environment.

5. Prioritization

Treatment priority must consider more than a technical score. Criteria include exploitation evidence, exposure, asset criticality, data, privilege, attack path, compensating controls, business impact, safety, recoverability, and supplier guidance.

6. Treatment timeframes

Approved treatment targets are [DEFINE BY SEVERITY AND CONTEXT]. Timeframes begin at [DEFINED EVENT] and may be shortened for active exploitation, internet exposure, critical services, or regulatory duties.

7. Treatment options

Treatment may include patching, configuration change, upgrade, removal, isolation, compensating control, service restriction, risk acceptance, or replacement. Decisions must address root exposure and be documented.

8. Testing and deployment

Updates must be tested proportionate to risk and deployed through approved change management. Emergency treatment may use accelerated procedures. Rollback, backup, compatibility, and service continuity must be considered.

9. Exceptions and risk acceptance

Missed treatment targets require documented risk, business and technical justification, interim controls, owner, expiration, monitoring, and approval by [AUTHORITY]. Repeated extensions require escalation.

10. Validation

Closure requires evidence that the vulnerability is remediated or otherwise treated. Rescanning, configuration verification, version confirmation, or equivalent validation must be independent of unsupported owner assertion.

11. Suppliers and unsupported technology

Supplier-managed vulnerabilities, end-of-life assets, and unavailable patches require documented coordination, contractual action, compensating controls, migration, and escalation.

12. Disclosure and reporting

External vulnerability reports must follow [DISCLOSURE PROCESS]. Internal metrics must cover coverage, age, overdue exposure, active exploitation, exceptions, recurrence, unsupported assets, and validation failures.

13. Records and review

Retain inventories, scan results, tickets, approvals, exceptions, validation, supplier correspondence, and metrics according to [RETENTION REQUIREMENT].

Logging and Monitoring Policy Template

Adapt privacy, workforce monitoring, communications secrecy, privilege, records, investigation, sector, and cross-border requirements before approval.

Document control

- Policy ID: [POLICY ID]
- Owner: [POLICY OWNER]
- Approver: [APPROVING AUTHORITY]
- Effective date: [DATE]
- Review date: [DATE]

1. Purpose

This policy establishes requirements for generating, collecting, protecting, retaining, reviewing, and using logs and monitoring information to support security, privacy, operations, resilience, investigations, compliance, and accountability.

2. Scope

Applies to [APPLICATIONS, CLOUD, NETWORKS, ENDPOINTS, IDENTITY, DATABASES, SECURITY TOOLS, OPERATIONAL TECHNOLOGY, FACILITIES, THIRD PARTIES, AND BUSINESS-CRITICAL SERVICES].

3. Logging requirements

Owners must define required events based on risk and obligations. Relevant events may include:

- authentication and access decisions;
- privileged and administrative activity;
- account and permission changes;
- security-control changes;
- configuration and deployment changes;
- data access, export, deletion, and high-risk processing;
- system, application, network, and service failures;
- malware, vulnerability, and threat detections;
- incident-response actions;
- backup, recovery, and continuity events;
- third-party access and significant supplier events.

4. Log quality

Logs must have sufficient time synchronization, source identity, event detail, integrity, and context to support their intended use. Sensitive data, credentials, secrets, and unnecessary personal information must not be logged unless specifically authorized and protected.

5. Collection and availability

Critical logs must be transmitted or protected to reduce unauthorized alteration or loss. Monitoring systems must have capacity, availability, access control, backup, and health monitoring proportionate to risk.

6. Retention

Retention periods must be defined by [RETENTION SCHEDULE], considering investigation, operations, contracts, privacy, legal holds, and regulatory duties. Longer retention is not automatically safer and must have documented purpose.

7. Access and confidentiality

Access to logs and monitoring tools must be least-privileged, approved, logged, and periodically reviewed. Investigation and employee-monitoring access require applicable legal, privacy, human-resources, and labor controls.

8. Monitoring and response

Use cases, alert thresholds, ownership, severity, escalation, response time, and evidence requirements must be documented. Alerts must be tested and tuned without suppressing material risk.

9. Third parties

Contracts and integrations should address log availability, notification, access, retention, time synchronization, investigation support, and secure transfer where applicable.

10. Privacy and proportionality

Monitoring must have a documented purpose, lawful authority, proportional scope, notice where required, access restrictions, retention limits, and review. This policy does not authorize unlawful or indiscriminate surveillance.

11. Validation and metrics

Validate source coverage, ingestion, parsing, time accuracy, alert operation, retention, search, access control, and response. Metrics should cover coverage gaps, source failures, alert backlog, false positives, response times, and unreviewed high-risk events.

12. Exceptions and records

Exceptions require documented risk, compensating controls, owner, duration, monitoring, and approval by [AUTHORITY]. Retain configuration, use cases, access reviews, tests, alerts, investigations, exceptions, and corrective actions according to approved requirements.